

DevSecOps

Installation et utilisation des outils

Exercice 1 – Détection de secrets avec Gitleaks

Contexte

Une équipe de développement vous demande d'auditer un dépôt Git afin de vérifier qu'aucun secret n'a été publié accidentellement.

Dépôt GitHub

<https://github.com/OWASP/wrongsecrets>

Travail demandé

1. Cloner le dépôt
2. Installer ou exécuter Gitleaks
3. Scanner le dépôt
4. Identifier les secrets détectés
5. Déterminer leur niveau de criticité
6. Proposer des actions correctives

Questions

- Combien de secrets ont été détectés ?
- Quels types de secrets et quels risques représentent-ils ?
- Comment éviter leur présence dans Git ?

Exercice 2 – Analyse statique de code (SAST) avec Semgrep

Contexte

Une API a été développée rapidement et doit être auditée avant sa mise en production.

Dépôt GitHub

<https://github.com/trottomv/python-insecure-app>

Travail demandé

1. Cloner le dépôt
2. Installer Semgrep
3. Lancer une analyse
4. Analyser les résultats
5. Identifier les vulnérabilités détectées
6. Proposer des corrections

Questions

- Quelles vulnérabilités ont été identifiées ?
- Quels risques présentent-elles ?
- Les résultats vous semblent-ils tous pertinents ?
- Quelles corrections recommanderiez-vous ?

Exercice 3 – Analyse des dépendances (SCA) avec Trivy

Contexte

Une application utilise de nombreuses bibliothèques Open Source. Vous devez vérifier si certaines contiennent des vulnérabilités connues.

Dépôt GitHub

<https://github.com/veracode/verademo>

Travail demandé

1. Cloner le dépôt
2. Installer Trivy
3. Scanner le système de fichiers
4. Identifier les dépendances vulnérables
5. Rechercher les CVE les plus critiques
6. Proposer un plan de mise à jour

Questions

- Combien de vulnérabilités sont détectées ?
- Quelle est la vulnérabilité la plus critique ?
- Quelle dépendance est concernée ?
- Quelle version corrige le problème ?

Exercice 4 – Analyse d'image Docker avec Trivy

Contexte

Avant la mise en production d'une application conteneurisée, l'équipe sécurité demande une analyse de l'image Docker.

Dépôt GitHub

<https://github.com/juice-shop/juice-shop>

Travail demandé

1. Cloner le dépôt
2. Construire l'image Docker
3. Scanner l'image
4. Analyser les vulnérabilités détectées
5. Identifier les plus critiques
6. Proposer des actions correctives

Questions

- Combien de vulnérabilités critiques sont présentes ?
- Quels composants sont concernés ?
- Quelles mises à jour permettraient de réduire le risque ?
- Le déploiement vous semble-t-il acceptable en l'état ?

Exercice 5 – Analyse d'Infrastructure as Code avec Checkov

Contexte

Une infrastructure AWS est décrite avec Terraform. Avant son déploiement, vous devez vérifier sa conformité aux bonnes pratiques de sécurité.

Dépôt GitHub

<https://github.com/bridgecrewio/terragoat>

Travail demandé

1. Cloner le dépôt
2. Installer Checkov
3. Lancer l'analyse
4. Étudier les résultats
5. Identifier les ressources à risque
6. Proposer des corrections

Questions

- Combien de contrôles échouent ?
- Quelles sont les erreurs de configuration les plus critiques ?
- Quels risques représentent-elles ?
- Comment les corriger ?